

Business / Risk Report — SRL-2018

Likelihood scale (FIRST 5-tier): almost_certain > highly_likely > likely > unlikely > remote. Likelihood estimates the probability of the assessed activity; it is kept separate from analytic confidence.

Confidence (LCA): high / moderate / low — the analyst's confidence in the assessment given evidence quality and corroboration. Distinct from likelihood.

Risk Register

Risk	Likelihood	Severity	Score	Business impact	Compliance	Owner	Analyst ref
Domain controller fully compromised — bi-daily service persistence + terminal C2 (base-dc)	highly_likely	critical	20	Catastrophic: control of the DC is control of every domain identity; trust in all credentials is void until a krbtgt double-reset completes.	NIST 800-53 AC-2/IA-5, ISO 27001 A.5.17, PCI-DSS 8.3, GDPR Art.32	Identity / AD	F-01
Pass-the-hash domain traversal across the DMZ→internal boundary	highly_likely	critical	20	Catastrophic for identity: any replayed credential is a standing re-entry key; the flat DMZ→internal trust converts one FTP foothold into domain compromise.	NIST 800-53 IA-5/SC-7, ISO 27001 A.5.17/A.8.22, PCI-DSS 1.3/8.3.1	Identity / Network	F-02
Active C2 channel live at the edge of collection (36s jitter-free beacon)	highly_likely	critical	20	High: an active operator held a live channel out of the network at containment; unconfirmed exfil keeps a disclosure-liability tail.	GDPR Art.33/34, NIS2, PCI-DSS 10.x	SOC + Legal/DPO	F-03
Six persistent backdoor local accounts on dmz-ftp	highly_likely	high	16	High: standing re-entry vector that survives credential resets; must be removed before any all-clear.	NIST 800-53 AC-2, ISO 27001 A.5.16, PCI-DSS 8.1.3	DMZ / infra ops	F-04
Scheduled-task / service	highly_likely	high	16	High: durable re-entry	NIST 800-53 SI-4, ISO	SOC / threat hunt	F-05

Risk	Likelihood	Severity	Score	Business impact	Compliance	Owner	Analyst ref
persistence on the DC (3 rotations)				independent of the C2 beacon; presence beyond base-dc inferred, not yet enumerated.	27001 A.8.16		
Credential harvesting in DC memory (findstr against credential stores)	likely	high	12	High: any secret recovered from the DC is a re-entry key; folds into the estate-wide credential rotation.	NIST 800-53 IA-5, ISO 27001 A.5.17, PCI-DSS 8.3.1	Identity / endpoint	F-06
Host / process reconnaissance on the DC (tasklist)	likely	medium	9	Medium: deliberate target selection on the DC raises credibility of follow-on actions.	NIST 800-53 SI-4, ISO 27001 A.8.16	SOC engineering	F-07
Defense evasion — event-log manipulation alongside DKOM unlinking	likely	medium	9	Medium: degrades timeline completeness and inflates analytic uncertainty across the case.	NIST 800-53 AU-9, ISO 27001 A.8.15	SOC engineering	F-08
Detection / audit-visibility gap — no EID 4688 command-line auditing	likely	medium	9	Medium: slow detection multiplies every other finding's blast radius; highest-leverage detective control to add.	NIST 800-53 AU-2/AU-12/SI-4, ISO 27001 A.8.15/A.8.16, PCI-DSS 10.x	SOC engineering	F-09